

The background is a dark blue field with glowing orange and blue circuit-like lines. Scattered throughout are hexagonal icons, some containing padlocks and others a globe. The overall aesthetic is high-tech and digital.

Comprehensive Risk Management Framework: An Integrated Approach to Information Security

Presenter: Roman Segal

Based on NIST SP 800-37, 800-30, and 800-39

The Challenge

- ⚠ Modern Cybersecurity Landscape
- ⚠ Organizations face increasingly sophisticated threats
- ⚠ Traditional siloed approaches prove inadequate
- ⚠ Need for unified, enterprise-wide risk management

NIST Framework Overview

Three Complementary Publications

NIST NIST SP 800-37 Rev. 2
Risk Management Framework (RMF)

NIST NIST SP 800-30 Rev. 1
Risk Assessment Guide

NIST NIST SP 800-39
Organizational Risk Management

Three-Tier Hierarchy:

Risk Management Across Organizational Levels

1

Tier 1: Organization Level

- Governance and strategy
- Enterprise-wide policies
- Risk tolerance establishment

2

Tier 2: Mission/Business Process Level

- Enterprise architecture
- Common controls
- Mission-specific requirements

3

Tier 3: Information System Level

- Individual system controls
- Technical implementation
- Operational assessments

Risk Assessment Components

Four Core Elements (SP 800-30)



Threat Sources

- Adversarial: Nation-states, criminals, insiders
- Non-adversarial: Accidents, natural disasters



Vulnerabilities

- System weaknesses
- Process gaps
- Predisposing conditions



Likelihood & Impact

- Probability of exploitation
- Potential consequences

Risk Response Strategies

Five Primary Approaches (SP 800-39)



Accept

Acknowledge without additional mitigation



Avoid

Eliminate through operational changes



Mitigate

Reduce through control implementation



Share

Distribute through partnerships



Transfer

Shift to external parties

Seven-Step RMF Lifecycle

Continuous Risk Management Framework (SP 800-37)



Integration Benefits

Unified Approach Advantages



Vertical Integration

Strategy flows to implementation
Consistent risk decisions



Horizontal Integration

Cross-mission coordination
Shared control effectiveness



Continuous Feedback

Real-time risk awareness
Adaptive management

Critical Elements for Effectiveness



Leadership Commitment

Senior executive engagement
Resource allocation
Cultural transformation



Automation & Monitoring

Continuous assessment capabilities
Real-time dashboards
Predictive analytics



Stakeholder Engagement

Clear role definition
Training and awareness
Communication channels

Conclusion & Questions

Key Takeaways

- ✓ Integrated approach addresses modern complexity
- ✓ Three-tier hierarchy ensures comprehensive coverage.
- ✓ Continuous monitoring enables adaptive management
- ✓ Cultural transformation drives sustainable success.

rsegal1@tamu.edu

<https://youtu.be/NM5DtQSD4b0>

YouTube Link

<https://youtu.be/NM5DtQSD4b0>

YouTube Link